

Solution Requirements

Date	30 September 2026
Project Name	Script-Controlled ACL – Restrict Record Access Based on Field Value
Maximum Marks	3 Marks

Define Functional and Non-Functional Requirements:

Create a comprehensive list of requirements to define exactly what the Script-Controlled ACL solution will do and how well it will perform. The solution uses ServiceNow users, roles, a custom Institution Details table, and script-controlled READ, CREATE, WRITE, and DELETE ACLs to enforce record-level access based on the Branch field and assigned roles.

1. Functional Requirements (FR) define specific behaviors, functions, or features of the system (What the system should do).
2. Non-Functional Requirements (NFR) specify the criteria that judge the operation of a system, rather than specific behaviors (How the system should be).

Fill out the descriptions and necessary details for each category provided below.

Step 1: Functional Requirements (FR)

S.No	Requirement Category	Requirement Description	Priority (High/Medium/Low)
1	Authentication	The solution shall use ServiceNow user authentication to verify the identity of users before they access the Institution Details records. Test users such as EEE User shall be created in User Administration → Users. Access to protected records shall be evaluated against the authenticated user's roles.	High
2	Authorization levels	The solution shall implement role-based authorization using custom roles bb1, bb2, bb3 and bb4. The bb1 role shall be required for READ access, bb2 for CREATE access, bb3 for WRITE access, and bb4 for DELETE access. The effective permissions shall be cumulative for users assigned multiple roles.	High
3	External interfaces	The solution shall operate within the ServiceNow platform and use native ServiceNow security	Low

		components such as Access Control (ACL), User Administration, System Definition → Tables, roles, conditions, and server-side ACL scripting. No external API, third-party database, or external service is required for the core solution.	
4	Transactions processing	The system shall control record transactions through ACL evaluation. READ requests shall be checked before records are displayed, CREATE requests shall be checked before a new record is inserted, WRITE requests shall be checked before an existing record is modified, and DELETE requests shall be checked before a record is removed. Unauthorized transactions shall be denied.	High
5	Reporting	The solution shall support verification through ServiceNow lists and forms. Administrators/testers shall be able to review Institution Details records and verify whether users with different role combinations can read, create, edit, or delete records. The verification output shall demonstrate that unauthorized users cannot perform restricted operations.	Medium
6	Business rules, etc.	The core access rule shall evaluate the authenticated user's role and the Branch value of the record. For READ access, users with the required bb1 role shall be permitted to view EEE branch records, while users without the required role shall be denied. The administrator role shall bypass the restriction and retain full access. CREATE, WRITE, and DELETE operations shall require bb2, bb3, and bb4 respectively.	High
7	Compliance to laws or regulations	The solution shall follow the organization's applicable data-access and privacy requirements by enforcing least-privilege access to student/institution-related records. Sensitive record data shall not be exposed to users who do not satisfy the configured ACL requirements. Applicable organizational ServiceNow security policies shall be followed.	Medium
8	Other	The solution shall provide separate record-level ACLs for READ, CREATE, WRITE, and DELETE operations on the u_institution_details table. ACLs shall be active, configured with the appropriate operation ,role requirements, and tested through user impersonation. The final solution shall clearly demonstrate the access behavior for each role	High

Step 2: Non-Functional Requirements (NFR)

S.No	NFR Category	Requirement Description	Target Metric / Acceptance Criteria
1	Performance & Speed	ACL evaluation shall occur as part of normal ServiceNow record access without introducing unnecessary processing. Opening an authorized list/form and evaluating access shall complete within the normal response time of the ServiceNow instance.	Target: normal ServiceNow response time; ACL script executes without unnecessary database calls or loops.
2	Scalability	The ACL design shall remain usable as the number of Institution Details records, branches, and authorized users increases. Access decisions shall be based on the current user's role and record values rather than maintaining manually duplicated permissions for individual records.	Acceptance: adding more records with ECE, EEE, or CSE values does not require creating a separate ACL for every record.
3	Security & Data Privacy	The solution shall enforce least-privilege record access through active ACLs and role checks. Unauthorized users shall not be able to bypass the configured READ, CREATE, WRITE, or DELETE controls through normal forms or lists. Administrator access shall remain available for authorized administration.	Acceptance: bb1 user can access permitted EEE records; users without required roles are denied; bb2/bb3/bb4 control CREATE/WRITE/DELETE respectively.
4	Reliability & Availability	Access control decisions shall be consistently enforced whenever the protected table is accessed. The ACL configuration shall remain active and should not depend on client-side UI controls alone. The system shall continue to enforce security when records are accessed through supported ServiceNow interfaces.	Acceptance: ACLs remain active and produce consistent authorization results during repeated tests using forms and lists.
5	Usability & Accessibility	Administrators shall be able to configure and verify the ACLs using the ServiceNow Application Navigator, System Security → Access Control (ACL), User Administration, and table configuration areas. Testers shall be able to use impersonation to validate each access scenario.	Acceptance: an administrator can locate the table, ACL records, roles, and test users and reproduce the documented verification steps.
6	Maintainability	The ACL configuration shall use separate, clearly identified ACL records for READ, CREATE, WRITE, and DELETE operations. Role names and business rules shall be documented so future administrators can understand and update the access model without changing unrelated security controls.	Acceptance: each operation has a dedicated ACL with a clear operation, table name, required role, and documented rule/script.

Detailed Solution Acceptance Summary

ACL	Table	Operation	Required Role	Expected Result
READ ACL	u_institution_details	record/read	bb1	EEE branch records are readable by the authorized user; unauthorized users are denied; admin retains access.
CREATE ACL	u_institution_details	record/create	bb2	Only users with the required create role can use the New operation to create records.
WRITE ACL	u_institution_details	record/write	bb3	Only users with the required write role can modify existing records.
DELETE ACL	u_institution_details	record/delete	bb4	Only users with the required delete role can remove existing records.

Project scope derived from the uploaded Script-Controlled ACL lab: the project creates users and roles, creates the Institution Details custom table and Branch field, configures script-controlled READ access, and adds separate CREATE, WRITE, and DELETE ACLs. Verification is performed by impersonating users with different role combinations and checking the resulting record operations.